

Narrativa explicativa para participantes – Encuesta OWASP 2025 – España

Texto para correo de invitación, página de presentación de la encuesta o nota del CISO

1. ¿Por qué recibe usted esta encuesta?

Si está leyendo estas líneas, es muy probable que tenga responsabilidad –formal o de facto– sobre la salud digital de su organización. Es decir, que cuando algo se cae, se cifra o se filtra, su teléfono forma parte del ecosistema de aparatos que empiezan a vibrar.

La presente encuesta forma parte de un esfuerzo coordinado para medir, con un poco más de ciencia y un poco menos de corazonadas, el grado de madurez de las organizaciones españolas en materia de seguridad de aplicaciones y ciberresiliencia, utilizando como brújula los marcos de OWASP (Top 10:2025, SAMM y ASVS 5.0) y las exigencias de NIS2 y del Esquema Nacional de Seguridad.

No se trata de un examen, sino de una radiografía: no buscamos culpables, sino datos.

2. ¿Qué queremos saber exactamente?

En términos muy sencillos, la encuesta pretende responder a preguntas como:

- ¿Hasta qué punto las vulnerabilidades que realmente nos afectan se parecen a las que describe OWASP en su Top 10:2025?
- ¿Qué grado de madurez tienen nuestros programas de desarrollo seguro, medidos con el modelo OWASP SAMM?
- ¿Verificamos nuestras aplicaciones con la profundidad que propone OWASP ASVS, o confiamos en pruebas esporádicas y la buena voluntad de los desarrolladores?
- ¿Cómo de conectadas están las decisiones de riesgo técnico con la alta dirección y con las obligaciones de NIS2 y ENS?
- ¿Qué papel juegan la cultura, la formación y la cadena de suministro en el cuadro completo?

En resumen: queremos dibujar un mapa de dónde estamos y hacia dónde deberíamos movernos.

3. ¿Qué se hace con sus respuestas?

Sus respuestas se utilizarán para:

1. Calcular indicadores de madurez y exposición a nivel de organización (Índice Global de Madurez, subíndices OWASP, etc.).
2. Agregar datos por sector, tamaño y tipo de entidad, de forma anonimizada.
3. Elaborar informes que permitan:
4. Identificar brechas comunes.
5. Priorizar esfuerzos de mejora.
6. Informar políticas públicas y estrategias sectoriales.

En ningún caso se publicarán resultados individualizados sin el consentimiento expreso de la organización. Los números sirven para aprender, no para señalar.

4. ¿Quién debería responder a la encuesta?

La experiencia muestra que los mejores resultados se obtienen cuando la encuesta no la rellena una sola persona heroica, sino un pequeño equipo coordinado. La combinación ideal incluye perfiles como:

- CISO o responsable de ciberseguridad.
- Responsable de TI / infraestructura.
- Responsable de desarrollo / DevSecOps.
- Responsable de gestión de riesgos y/o cumplimiento.

No es necesario que todos respondan al formulario, pero sí que aporten su visión y datos en los bloques que les corresponden.

5. ¿Cuánto tiempo llevará?

Si su organización tiene los datos razonablemente estructurados, completar la encuesta llevará entre 45 y 90 minutos. Si algunos datos exigen pequeñas expediciones arqueológicas a antiguos Excel o wikis, el tiempo puede ser algo mayor, pero la inversión suele amortizarse en forma de claridad y discusiones internas productivas.

Puede completarse en varias sesiones, por bloques, y volver a ella tantas veces como sea necesario antes del envío final.

6. ¿Qué obtiene su organización a cambio?

Además de la satisfacción íntima de contribuir a un diagnóstico nacional, su organización recibirá:

- Un informe individual con su puntuación en el Índice Global de Madurez y en los subíndices OWASP.
- Una comparación anónima con el promedio de su sector y de organizaciones de tamaño similar.
- Recomendaciones generales de mejora alineadas con OWASP, NIS2 y ENS.

En otras palabras: un espejo más nítido que el que proporcionan las presentaciones habituales de “estado de la ciberseguridad”.

7. ¿Cómo queremos que responda?

Con honestidad. No pasa nada por marcar que algo no se hace, si ese es el caso; de hecho, es la única forma de que los resultados sean útiles. La encuesta está diseñada para que incluso las respuestas incómodas sean informativas, no inculminatorias.

Algunas opciones de respuesta incluyen un toque irónico o literario. No es un accidente: a veces un poco de humor ayuda a nombrar realidades que preferimos evitar. Le rogamos que no confunda el estilo con ligereza: el objetivo es profundamente serio.

8. ¿Qué relación tiene todo esto con NIS2 y el ENS?

Las preguntas no se han elegido al azar. Cada bloque está alineado con:

- Obligaciones de gestión de riesgos, medidas técnicas y gobernanza de NIS2.
- Exigencias del ENS en términos de análisis de riesgos, medidas organizativas, técnicas y de continuidad.
- Mejores prácticas de OWASP en materia de desarrollo seguro y verificación.

La idea es que los resultados le sirvan a usted tanto para hablar con desarrolladores y arquitectos en lenguaje OWASP como para dialogar con reguladores y auditores en idioma NIS2/ENS.

9. ¿Qué hacemos si no tenemos todos los datos?

Es normal que algunas preguntas requieran estimaciones razonables o respuestas parciales. En esos casos:

- Use la mejor aproximación disponible, indicando en comentarios si se trata de una estimación.
- Identifique qué datos le gustaría poder medir mejor en el futuro; esa lista suele ser el embrión de un buen plan de métricas.

Lo importante es evitar dos extremos igualmente peligrosos: responder “no lo sé” a casi todo, o contestar “idealmente sí” en lugar de “realmente no”.

10. Cierre: una invitación propositiva

Vivimos un momento en el que la ciberseguridad ha dejado de ser un asunto de especialistas para convertirse en tema de Consejo. La Directiva NIS2 y el ENS no son solo un nuevo capítulo regulatorio, sino una invitación a tomarse en serio la resiliencia digital.

Esta encuesta aspira a ayudarle a poner números donde antes había intuiciones, y a traducir marcos técnicos como los de OWASP en conversaciones comprensibles para negocio y alta dirección.

Si al terminarla siente que ha descubierto un par de cosas que preferiría no saber... enhorabuena: justo ahí empieza el trabajo interesante.